Jr.Pen. 14.1. Active Directory Basics

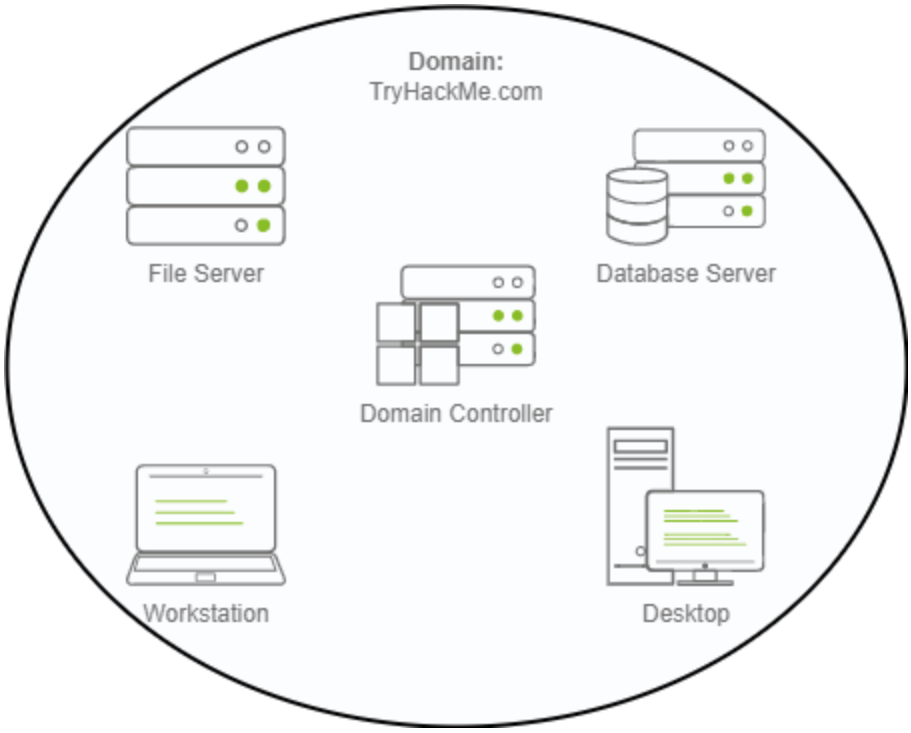
Active Directory Basics

Task 1 - Introduction

Microsoft's Active Directory is the backbone of the corporate world. It simplifies the management of devices and users within a corporate environment.

Task 2 - Windows Domains

Windows domain is a group of users and computers under the administration of a given business. The main idea behind a domain is to centralise the administration of common components of a Windows computer network in a single repository called **Active Directory (AD)**. The server that runs the Active Directory services is known as a **Domain Controller (DC)**.



The main advantages of having a configured Windows domain are:

- **Centralised identity management:** All users across the network can be configured from Active Directory with minimum effort.
- **Managing security policies:** You can configure security policies directly from Active Directory and apply them to users and computers across the network as needed.

Answer the questions below

> In a Windows domain, credentials are stored in a centralised repository called.

Active Directory

> The server in charge of running the Active Directory services is called.

Domain Controller

Task 3 - Active Directory

The core of any Windows Domain is the **Active Directory Domain Service (AD DS)**. This service acts as a catalogue that holds the information of all of the "objects" that exist on your network. Amongst the many objects supported by AD, we have users, groups, machines, printers, shares and many others. Let's look at some of them:

Users are one of the most common object types in Active Directory. Users are one of the objects known as **security principals**, meaning that they can be authenticated by the domain and can be assigned privileges over **resources** like files or printers. You could say that a security principal is an object that can act upon resources in the network.

Users can be used to represent two types of entities:

- **People:** users will generally represent persons in your organisation that need to access the network, like employees.
- **Services:** you can also define users to be used by services like IIS or MSSQL. Every single service requires a user to run, but service users are different from

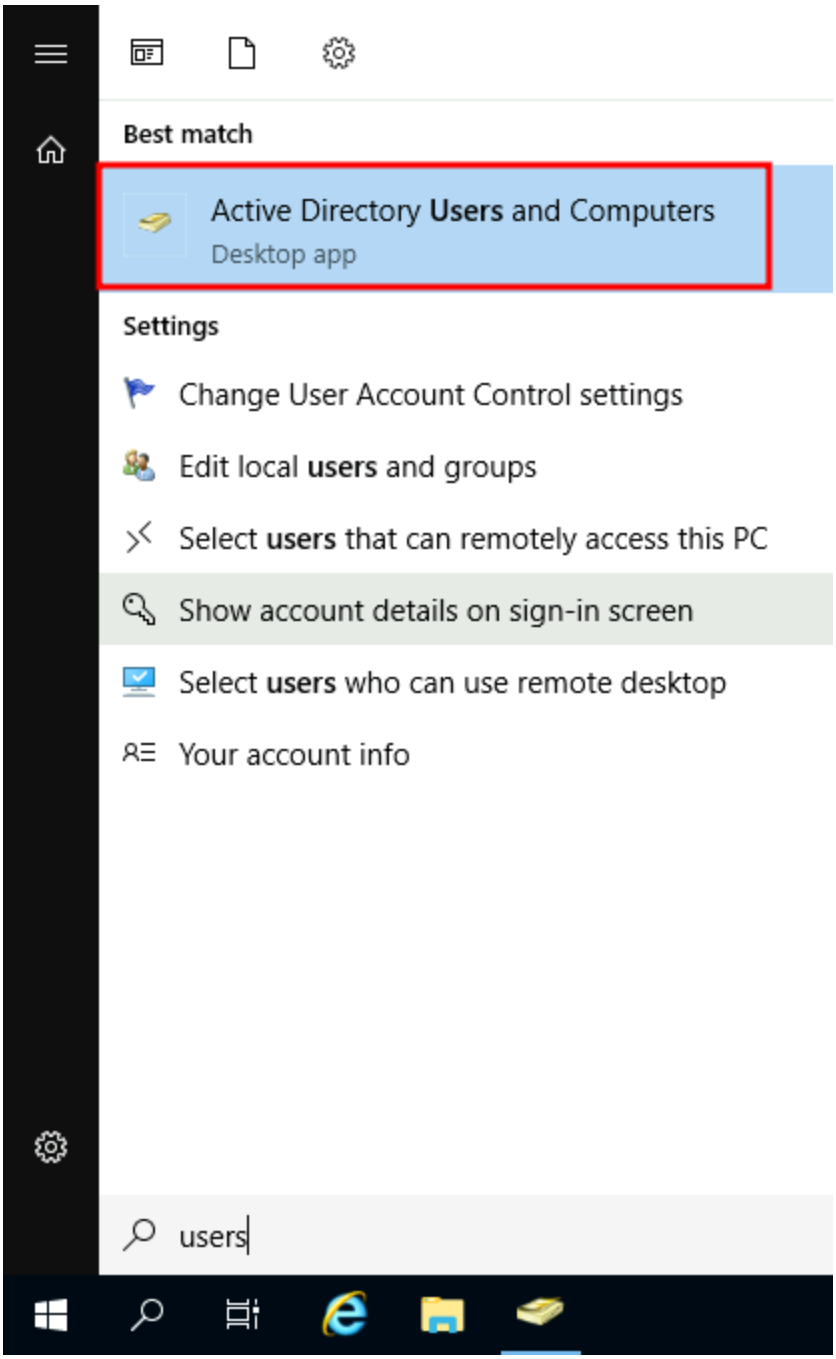
regular users as they will only have the privileges needed to run their specific service.

Machines are another type of object within Active Directory; for every computer that joins the Active Directory domain, a machine object will be created. Machines are also considered "security principals" and are assigned an account just as any regular user. This account has somewhat limited rights within the domain itself.

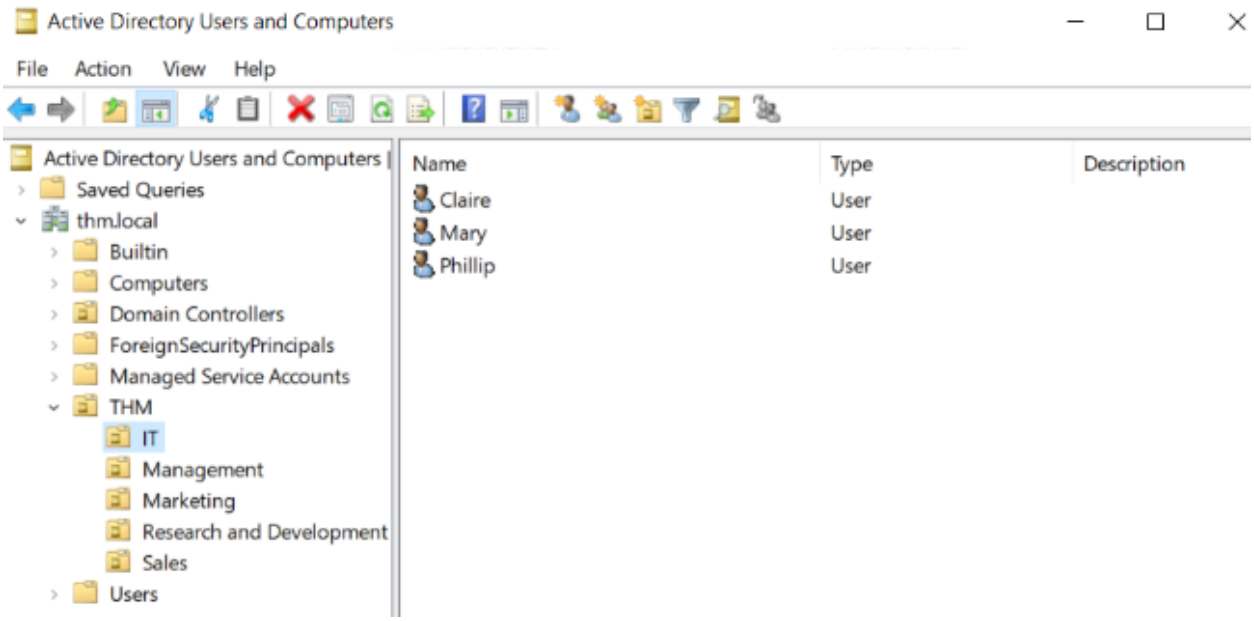
Several groups are created by default in a domain that can be used to grant specific privileges to users. As an example, here are some of the most important groups in a domain:

Security Group	Description
Domain Admins	Users of this group have administrative privileges over the entire domain. By default, they can administer any computer on the domain, including the DCs.
Server Operators	Users in this group can administer Domain Controllers. They cannot change any administrative group memberships.
Backup Operators	Users in this group are allowed to access any file, ignoring their permissions. They are used to perform backups of data on computers.
Account Operators	Users in this group can create or modify other accounts in the domain.
Domain Users	Includes all existing user accounts in the domain.
Domain Computers	Includes all existing computers in the domain.
Domain Controllers	Includes all existing DCs on the domain.

Active Directory Users and Computers: To configure users, groups or machines in Active Directory, we need to log in to the Domain Controller and run "Active Directory Users and Computers" from the start menu:



This will open up a window where you can see the hierarchy of users, computers and groups that exist in the domain. These objects are organised in **Organizational Units (OUs)** which are container objects that allow you to classify users and machines. OUs are mainly used to define sets of users with similar policing requirements.



These containers are created by Windows automatically and contain the following:

- **Builtin:** Contains default groups available to any Windows host.
- **Computers:** Any machine joining the network will be put here by default. You can move them if needed.
- **Domain Controllers:** Default OU that contains the DCs in your network.
- **Users:** Default users and groups that apply to a domain-wide context.
- **Managed Service Accounts:** Holds accounts used by services in your Windows domain.

Security Groups vs OUs: While both are used to classify users and computers, their purposes are entirely different:

- **OUs** are handy for **applying policies** to users and computers, which include specific configurations that pertain to sets of users depending on their particular role in the enterprise. Remember, a user can only be a member of a single OU at a time, as it wouldn't make sense to try to apply two different sets of policies to a single user.
- **Security Groups**, on the other hand, are used to **grant permissions over resources**. For example, you will use groups if you want to allow some users to access a shared folder or network printer. A user can be a part of many groups, which is needed to grant access to multiple resources.

Answer the questions below

> Which group normally administrates all computers and resources in a domain? Domain Admins

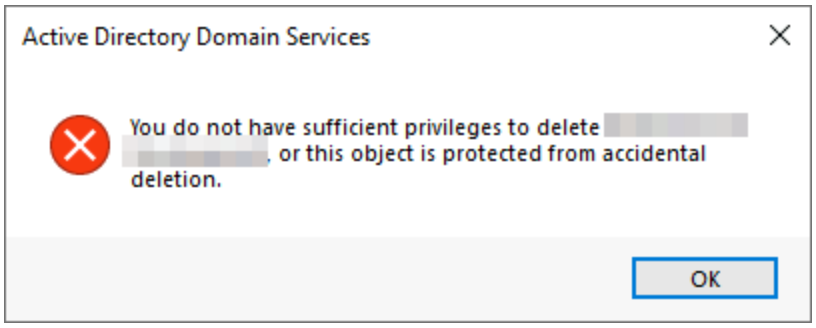
> What would be the name of the machine account associated with a machine named TOM-PC? TOM-PC$

> Suppose our company creates a new department for Quality Assurance. What type of containers should we use to group all Quality Assurance users so that policies can be applied consistently to them? Organizational Units

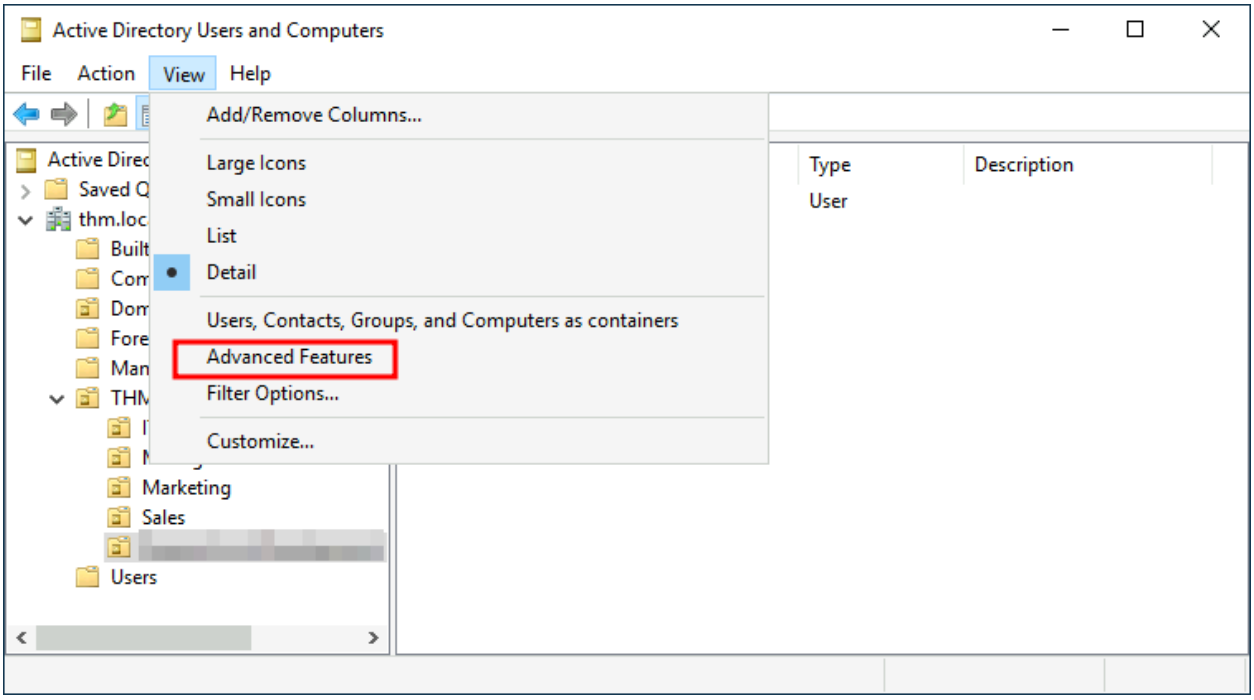
Task 4 - Managing Users in AD

Deleting extra OUs and users:

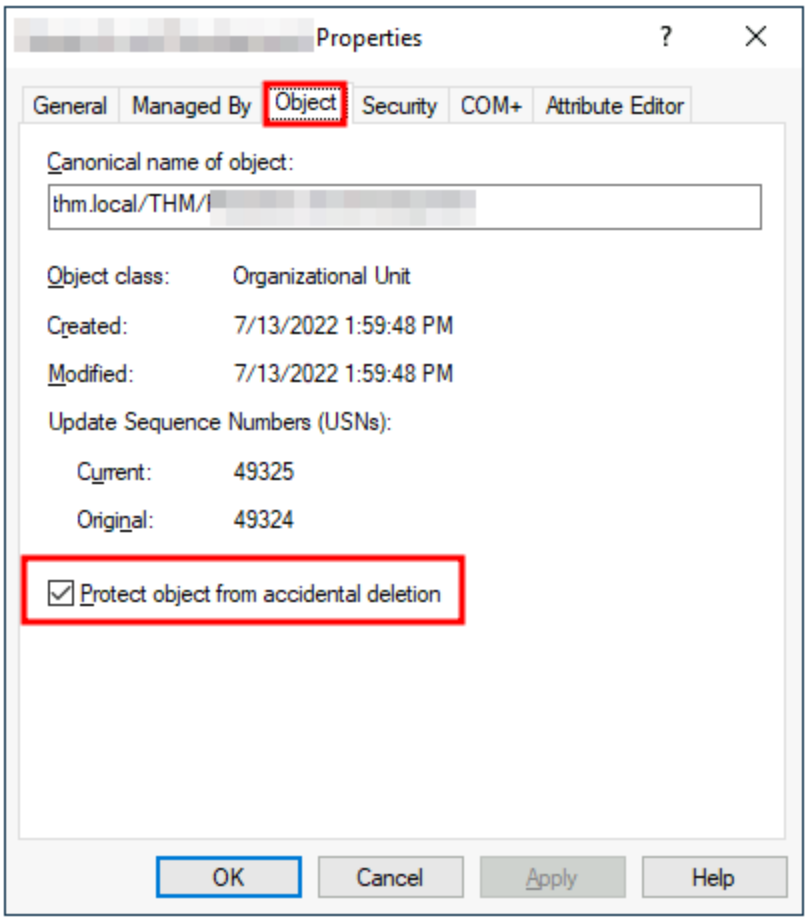
The first thing you should notice is that there is an additional department OU in your current AD configuration that doesn't appear in the chart.



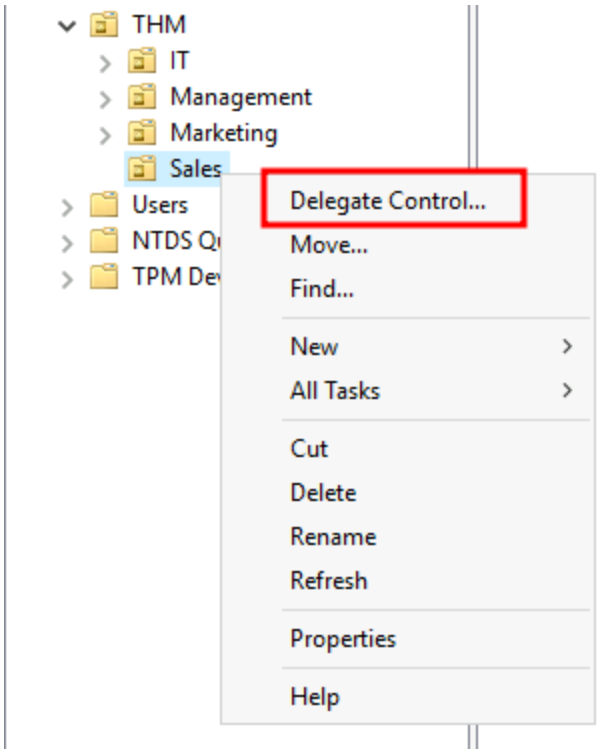
By default, OUs are protected against accidental deletion. To delete the OU, we need to enable the **Advanced Features** in the View menu:



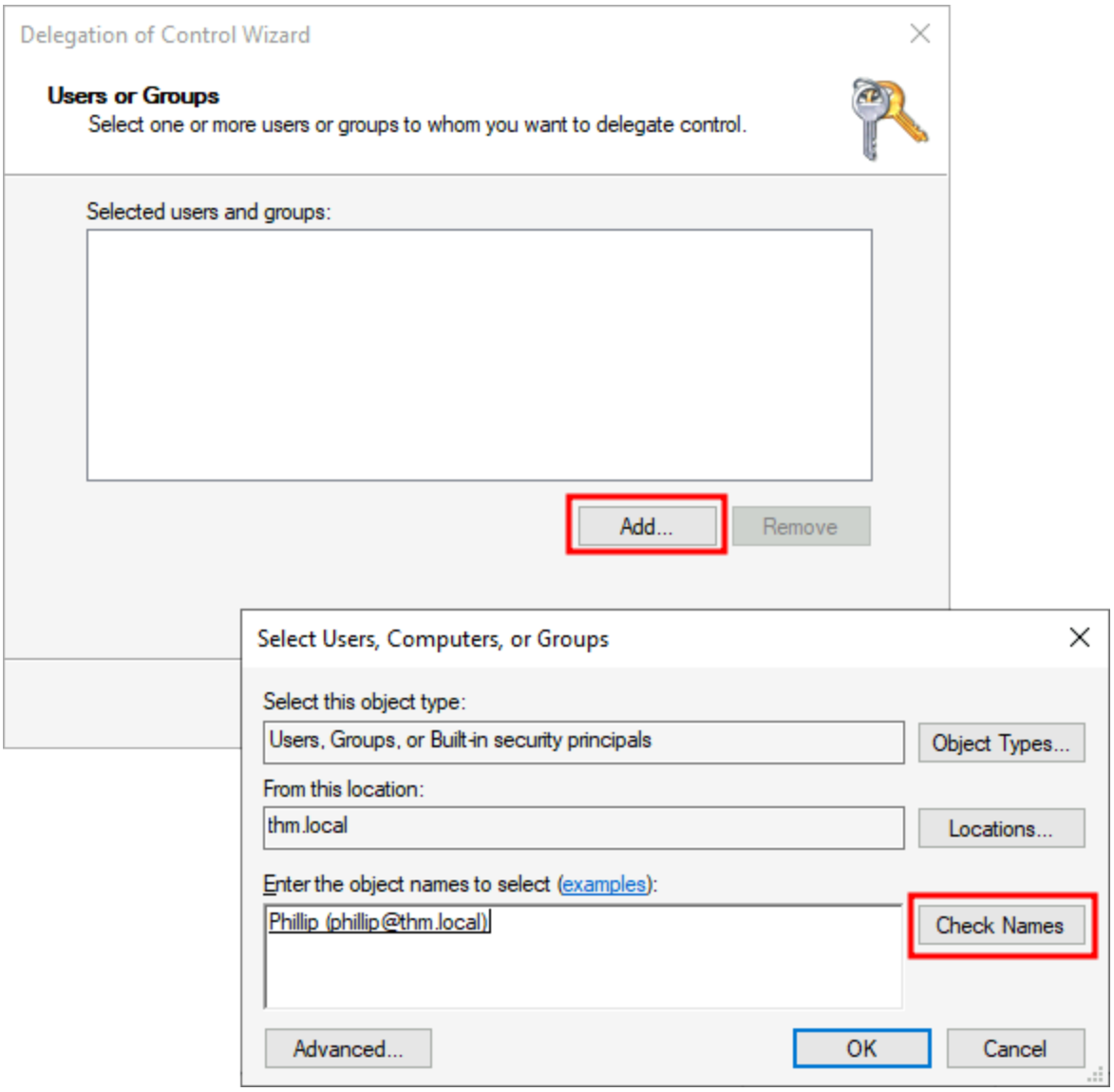
This will show you some additional containers and enable you to disable the accidental deletion protection. To do so, right-click the OU and go to Properties. You will find a checkbox in the Object tab to disable the protection:



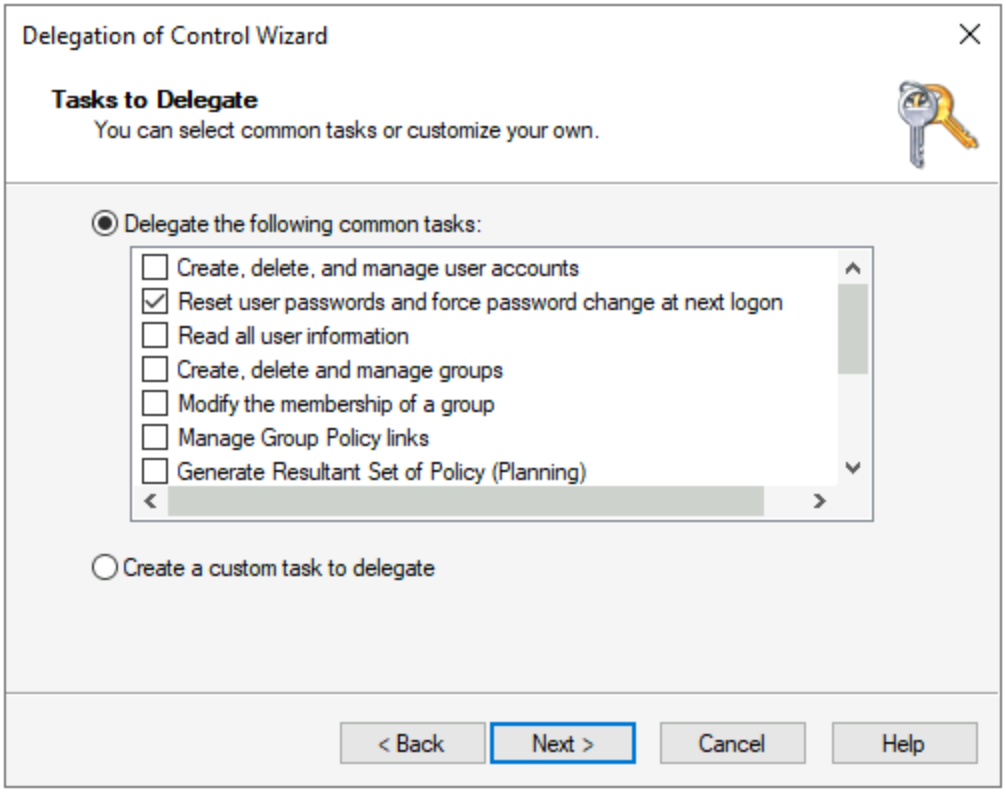
Delegation: One of the nice things you can do in AD is to give specific users some control over some OUs. This process is known as **delegation** and allows you to grant users specific privileges to perform advanced tasks on OUs without needing a Domain Administrator to step in.



Note: To avoid mistyping the user's name, write "phillip" and click the **Check Names** button. Windows will autocomplete the user for you.



Click OK, and on the next step, select the following option:

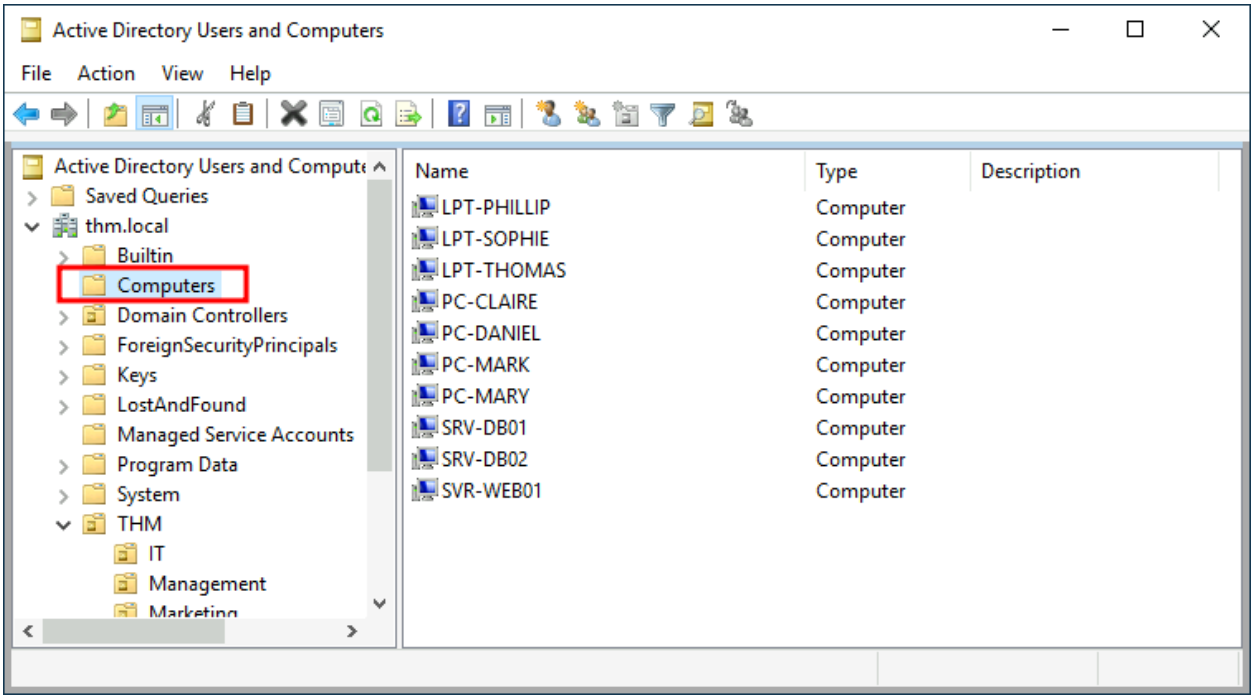


Answer the questions below

> What was the flag found on Sophie's desktop?
> THM{thanks_for_contacting_support}

> The process of granting privileges to a user over some OU or other AD Object is called. delegation

Task 5 - Managing Computers in AD

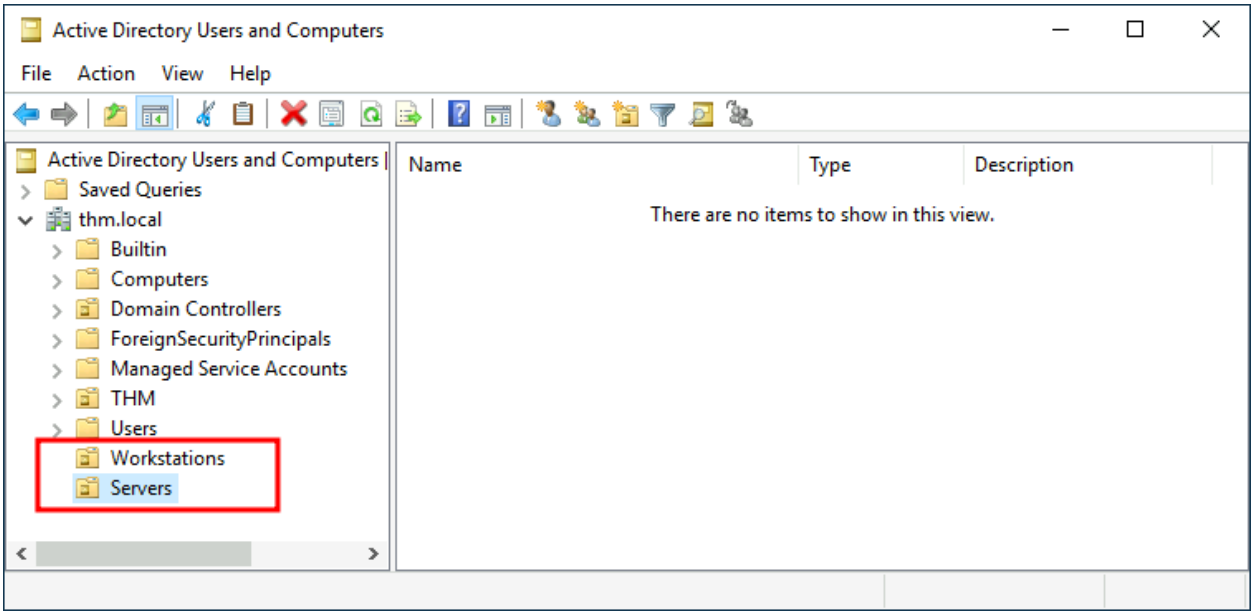


Devices divided into at least the three following categories:

1. Workstations: Workstations are one of the most common devices within an Active Directory domain. Each user in the domain will likely be logging into a workstation. This is the device they will use to do their work or normal browsing activities. These devices should never have a privileged user signed into them.

2. Servers: Servers are the second most common device within an Active Directory domain. Servers are generally used to provide services to users or other servers.

3. Domain Controllers: Domain Controllers are the third most common device within an Active Directory domain. Domain Controllers allow you to manage the Active Directory Domain. These devices are often deemed the most sensitive devices within the network as they contain hashed passwords for all user accounts within the environment.



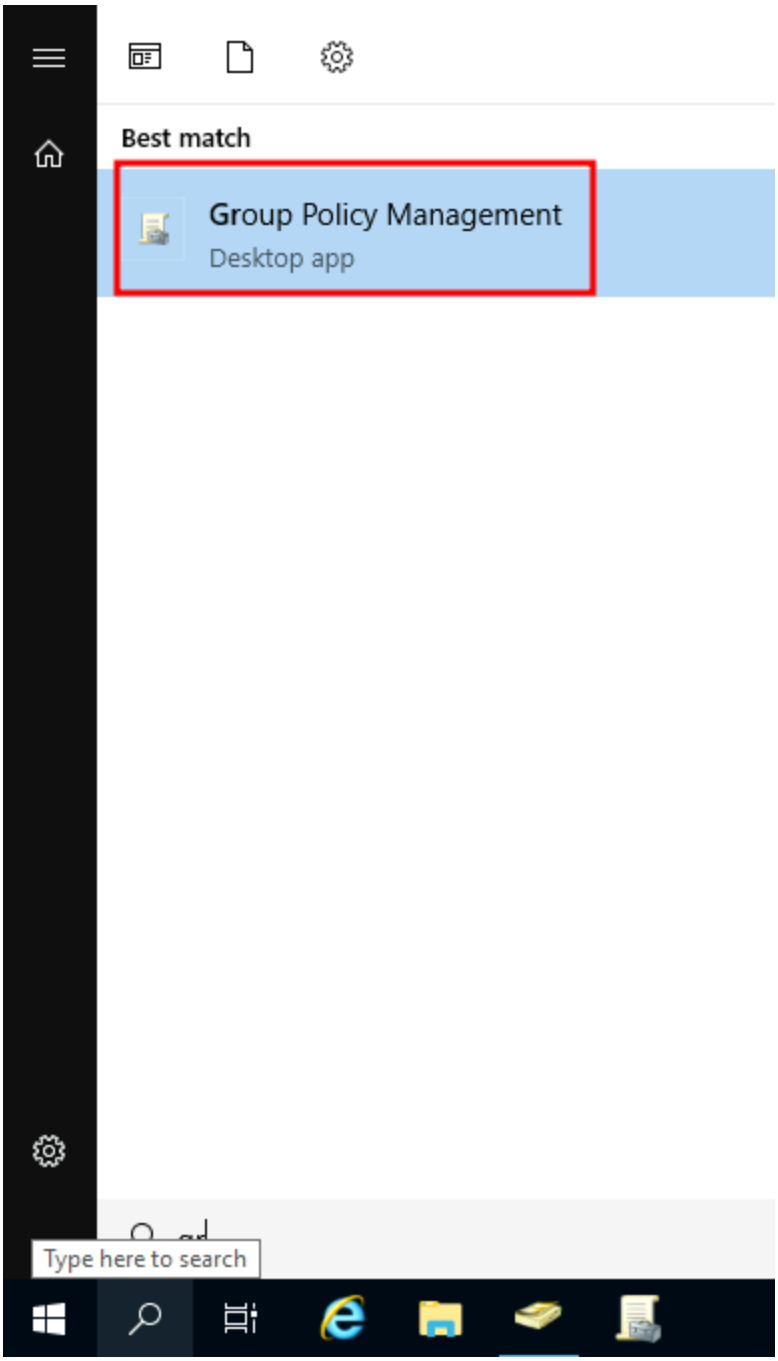
Answer the questions below

> After organising the available computers, how many ended up in the Workstations OU? 7

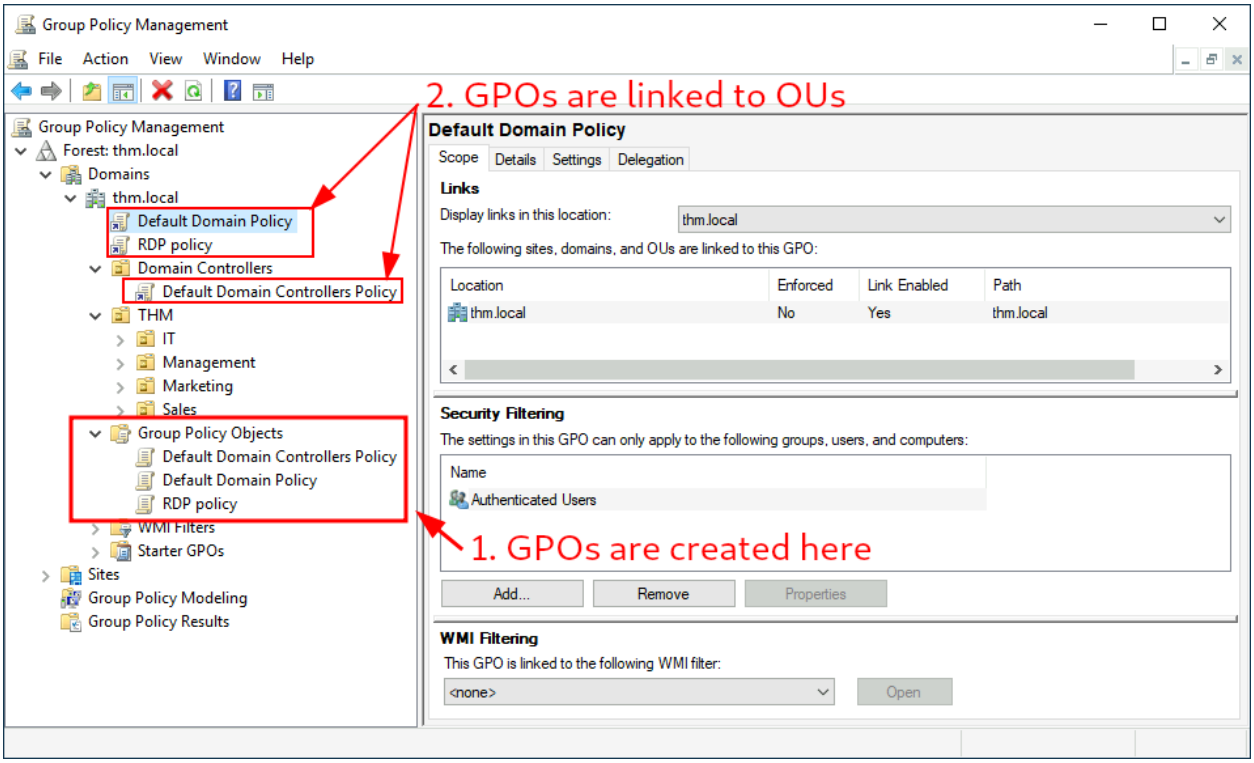
> Is it recommendable to create separate OUs for Servers and Workstations? yay

Task 6 -Group Policies

Windows manages such policies through **Group Policy Objects (GPO)**. GPOs are simply a collection of settings that can be applied to OUs. GPOs can contain policies aimed at either users or computers, allowing you to set a baseline on specific machines and identities. To configure GPOs, you can use the **Group Policy Management** tool, available from the start menu:

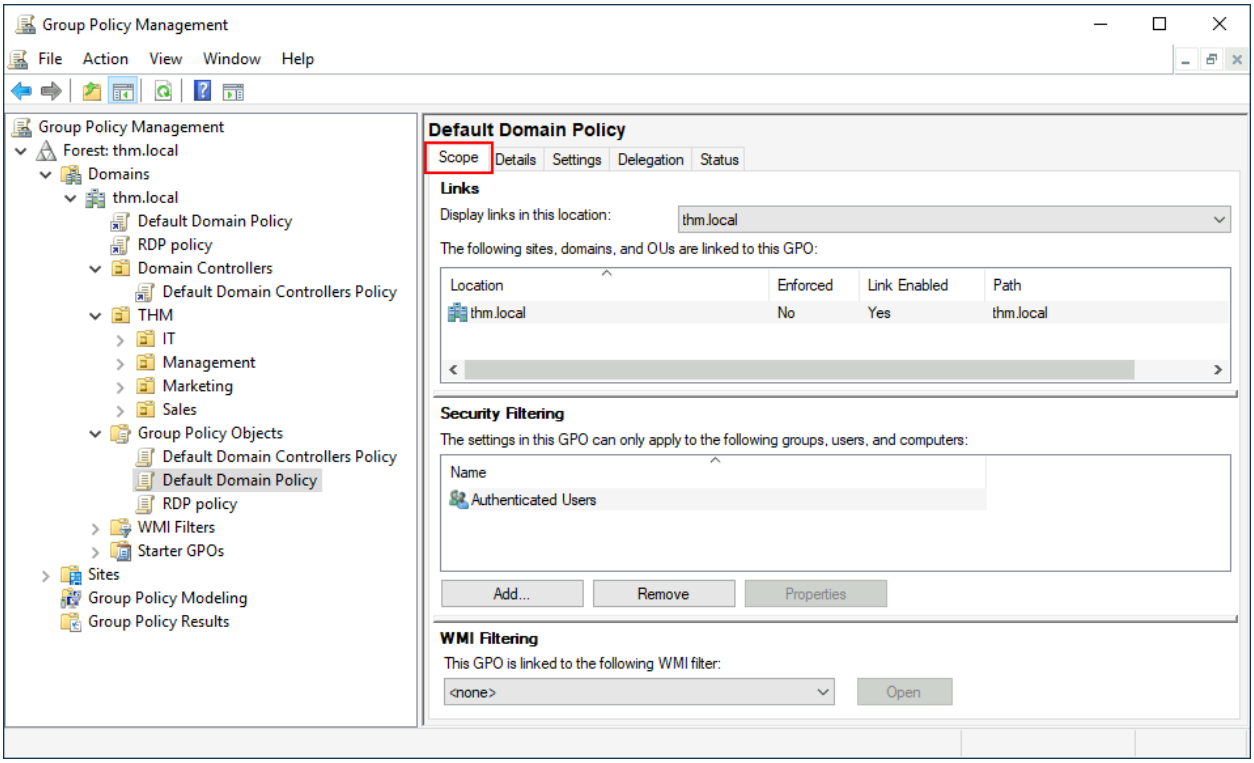


The first thing you will see when opening it is your complete OU hierarchy, as defined before. To configure Group Policies, you first create a GPO under **Group Policy Objects** and then link it to the OU where you want the policies to apply. As an example, you can see there are some already existing GPOs in your machine:



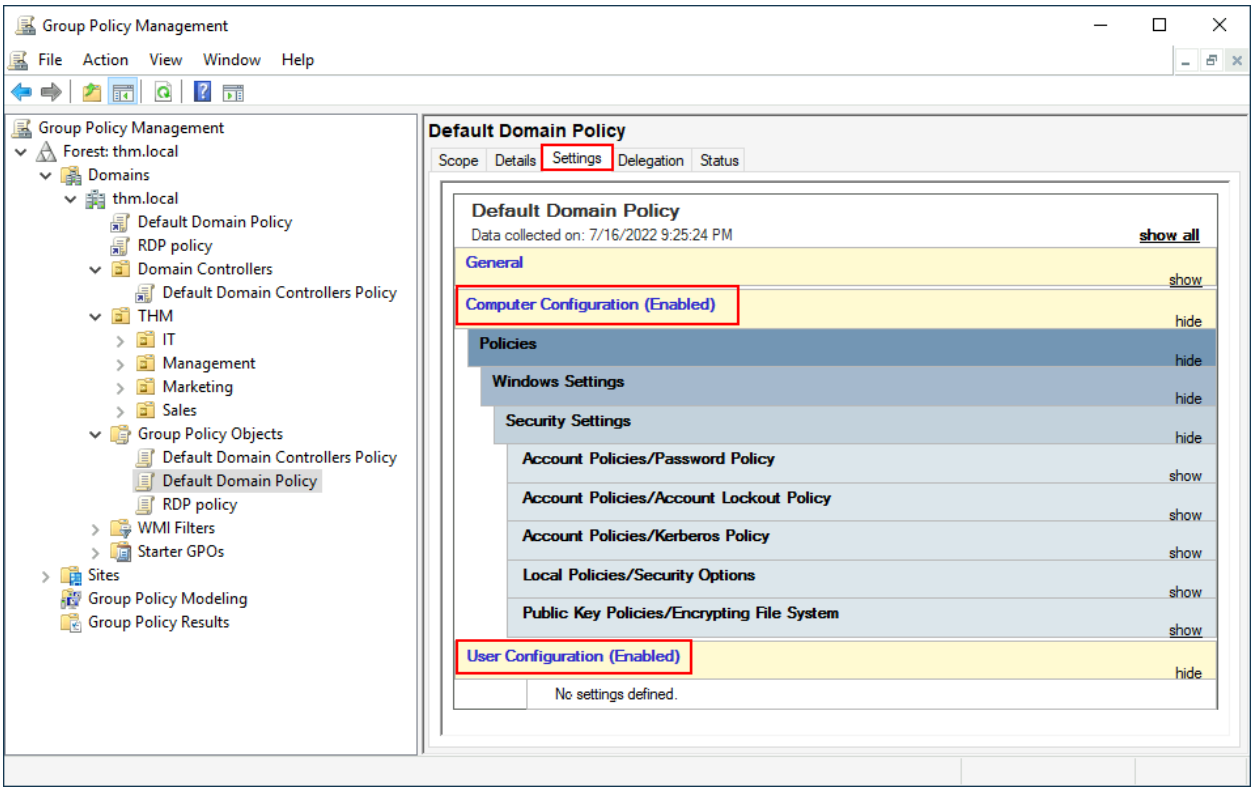
We can see in the image above that 3 GPOs have been created. From those, the `Default Domain Policy` and `RDP Policy` are linked to the `thm.local` domain as a whole, and the `Default Domain Controllers Policy` is linked to the `Domain Controllers` OU only. Something important to have in mind is that any GPO will apply to the linked OU and any sub-OUs under it. For example, the `Sales` OU will still be affected by the `Default Domain Policy`.

Let's examine the `Default Domain Policy` to see what's inside a GPO. The first tab you'll see when selecting a GPO shows its **scope**, which is where the GPO is linked in the AD. For the current policy, we can see that it has only been linked to the `thm.local` domain:

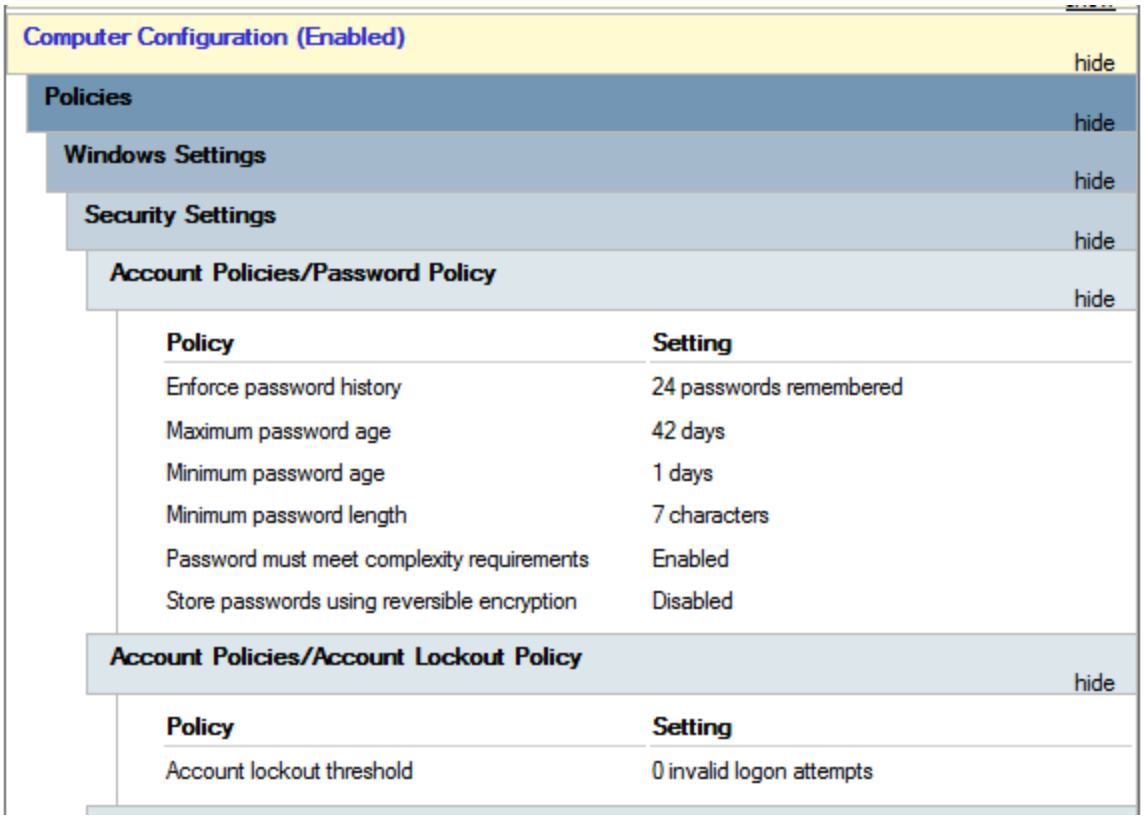


As you can see, you can also apply **Security Filtering** to GPOs so that they are only applied to specific users/computers under an OU. By default, they will apply to the **Authenticated Users** group, which includes all users/PCs.

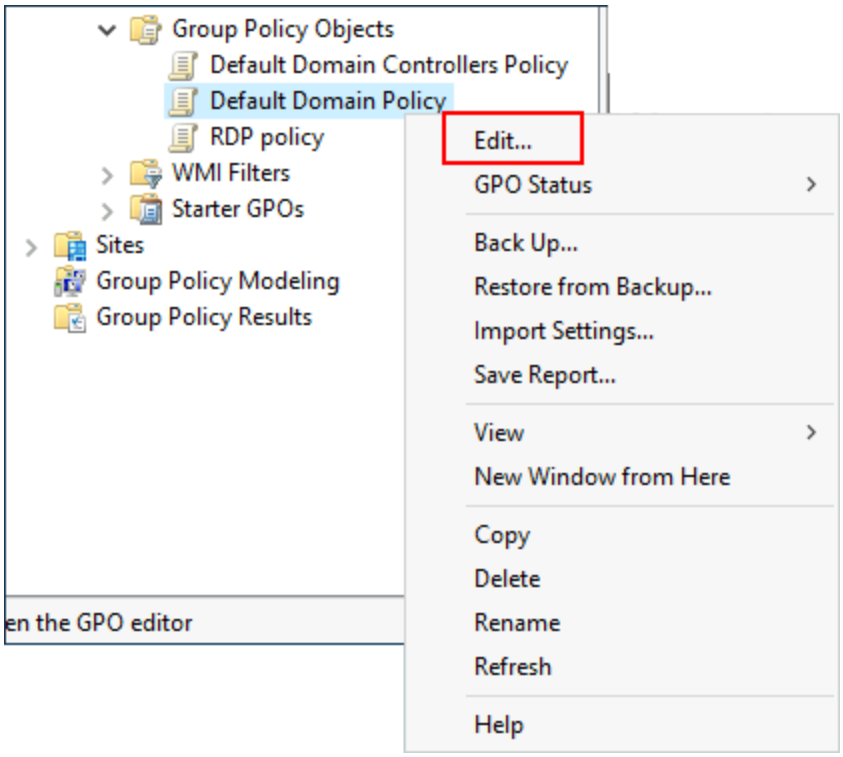
The **Settings** tab includes the actual contents of the GPO and lets us know what specific configurations it applies. As stated before, each GPO has configurations that apply to computers only and configurations that apply to users only. In this case, the `Default Domain Policy` only contains Computer Configurations:



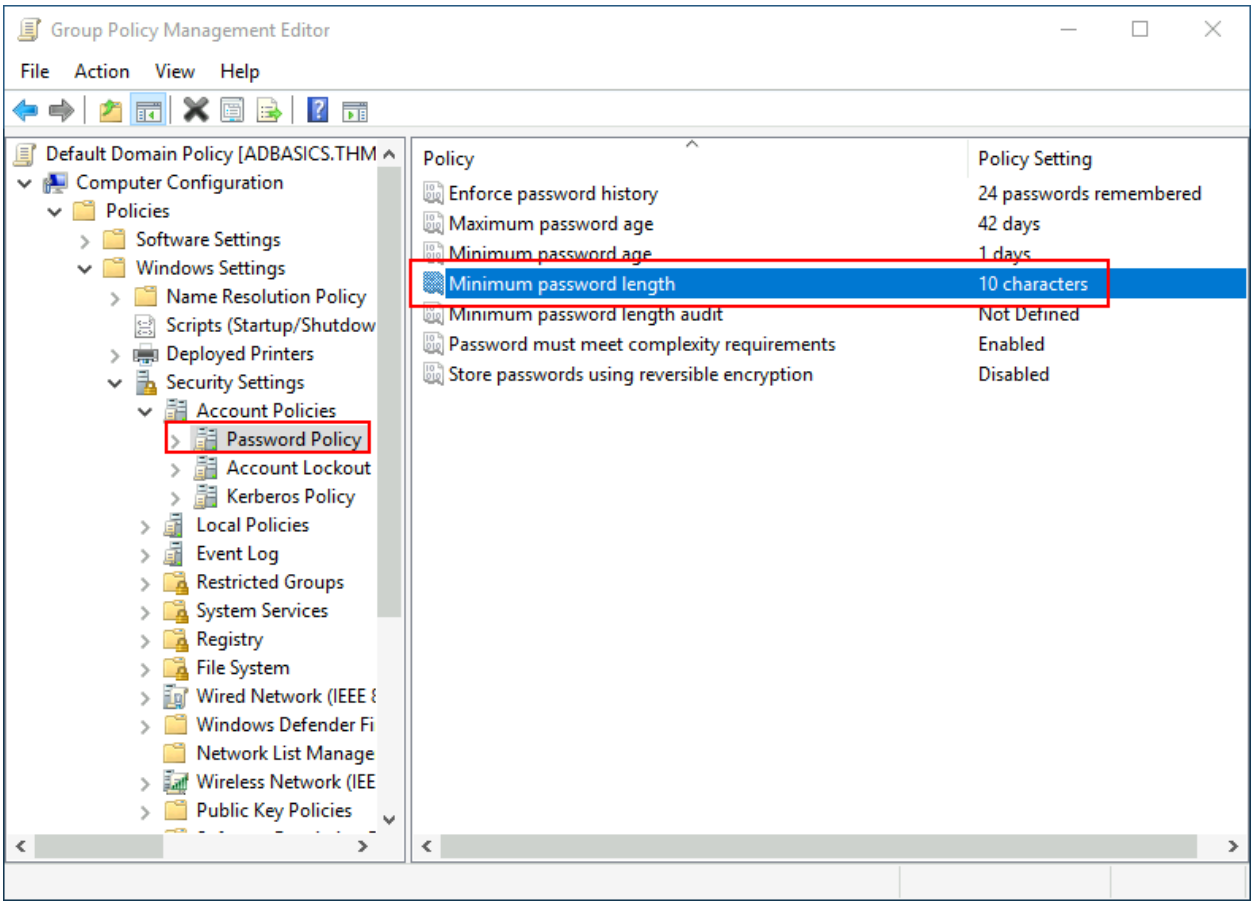
Feel free to explore the GPO and expand on the available items using the "show" links on the right side of each configuration. In this case, the `Default Domain Policy` indicates really basic configurations that should apply to most domains, including password and account lockout policies:



Since this GPO applies to the whole domain, any change to it would affect all computers. Let's change the minimum password length policy to require users to have at least 10 characters in their passwords. To do this, right-click the GPO and select **Edit**:



This will open a new window where we can navigate and edit all the available configurations. To change the minimum password length, go to `Computer Configurations -> Policies -> Windows Setting -> Security Settings -> Account Policies -> Password Policy` and change the required policy value:



As you can see, plenty of policies can be established in a GPO. While explaining every single of them would be impossible in a single room, do feel free to explore a bit, as some of the policies are straightforward. If more information on any of the policies is needed, you can double-click them and read the **Explain** tab on each of them:



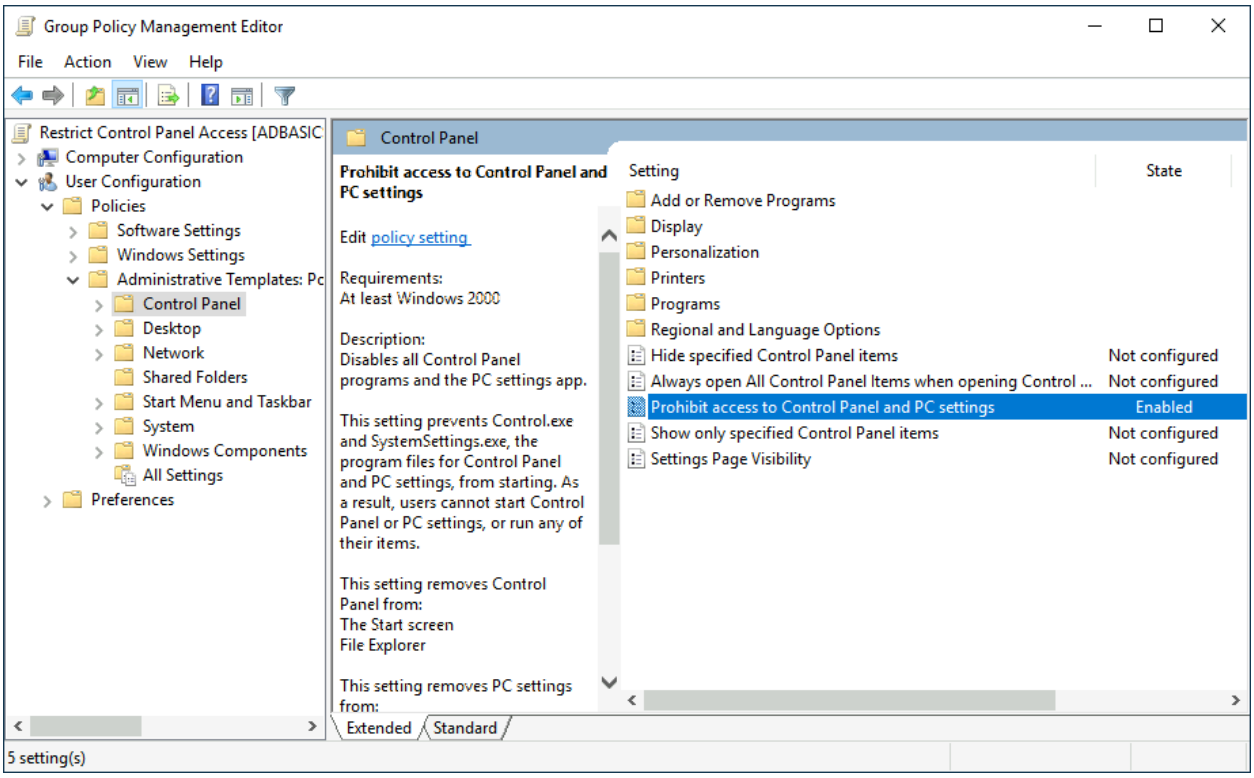
GPO distribution: GPOs are distributed to the network via a network share called `SYSVOL`, which is stored in the DC. All users in a domain should typically have access to this share over the network to sync their GPOs periodically. The SYSVOL share points by default to the `C:\Windows\SYSVOL\sysvol\` directory on each of the DCs in our network.

```
PS C:\> gpupdate /force
```

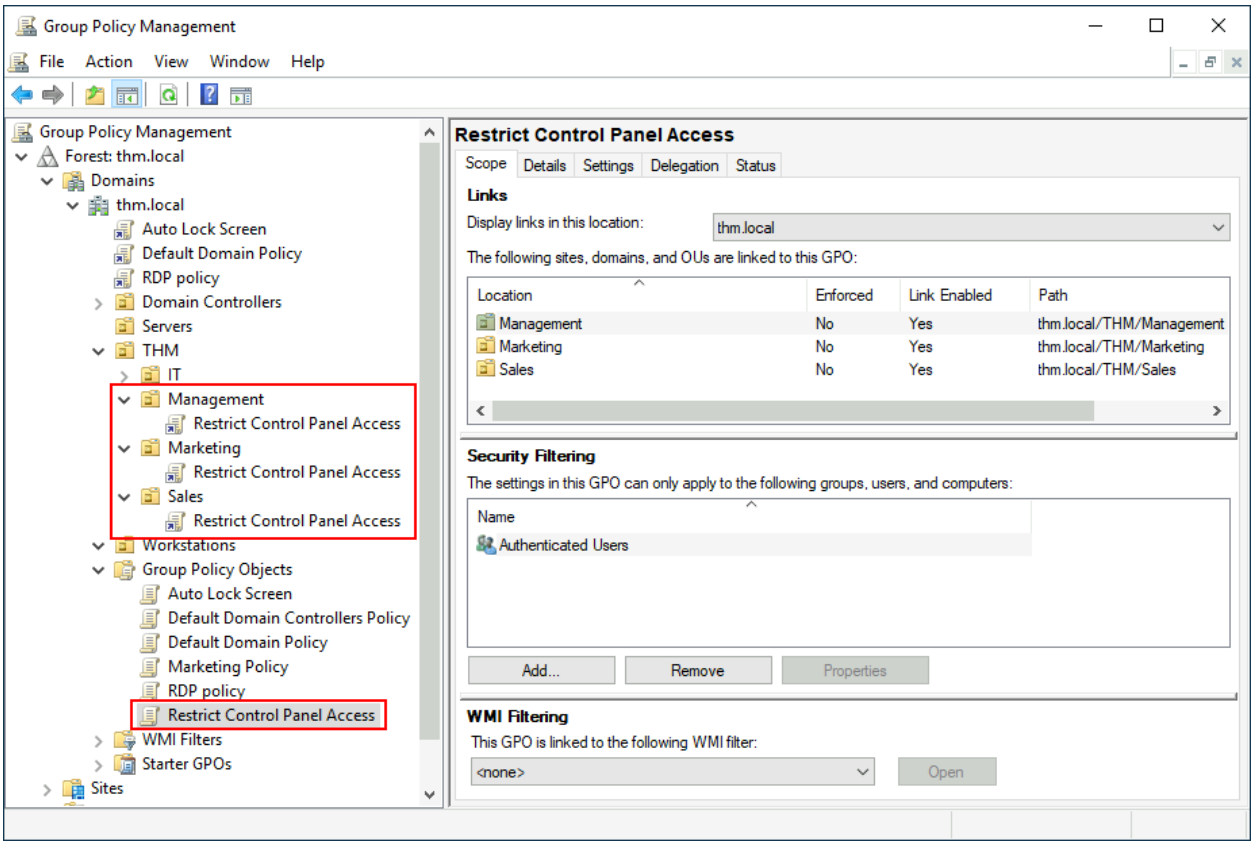
Creating some GPOs for THM Inc.: As part of our new job, we have been tasked with implementing some GPOs to allow us to:

1. Block non-IT users from accessing the Control Panel.
2. Make workstations and servers lock their screen automatically after 5 minutes of user inactivity to avoid people leaving their sessions exposed.

Restrict Access to Control Panel: We want to restrict access to the Control Panel across all machines to only the users that are part of the IT department. Users of other departments shouldn't be able to change the system's preferences. Let's create a new GPO called `Restrict Control Panel Access` and open it for editing. Since we want this GPO to apply to specific users, we will look under `User Configuration` for the following policy:

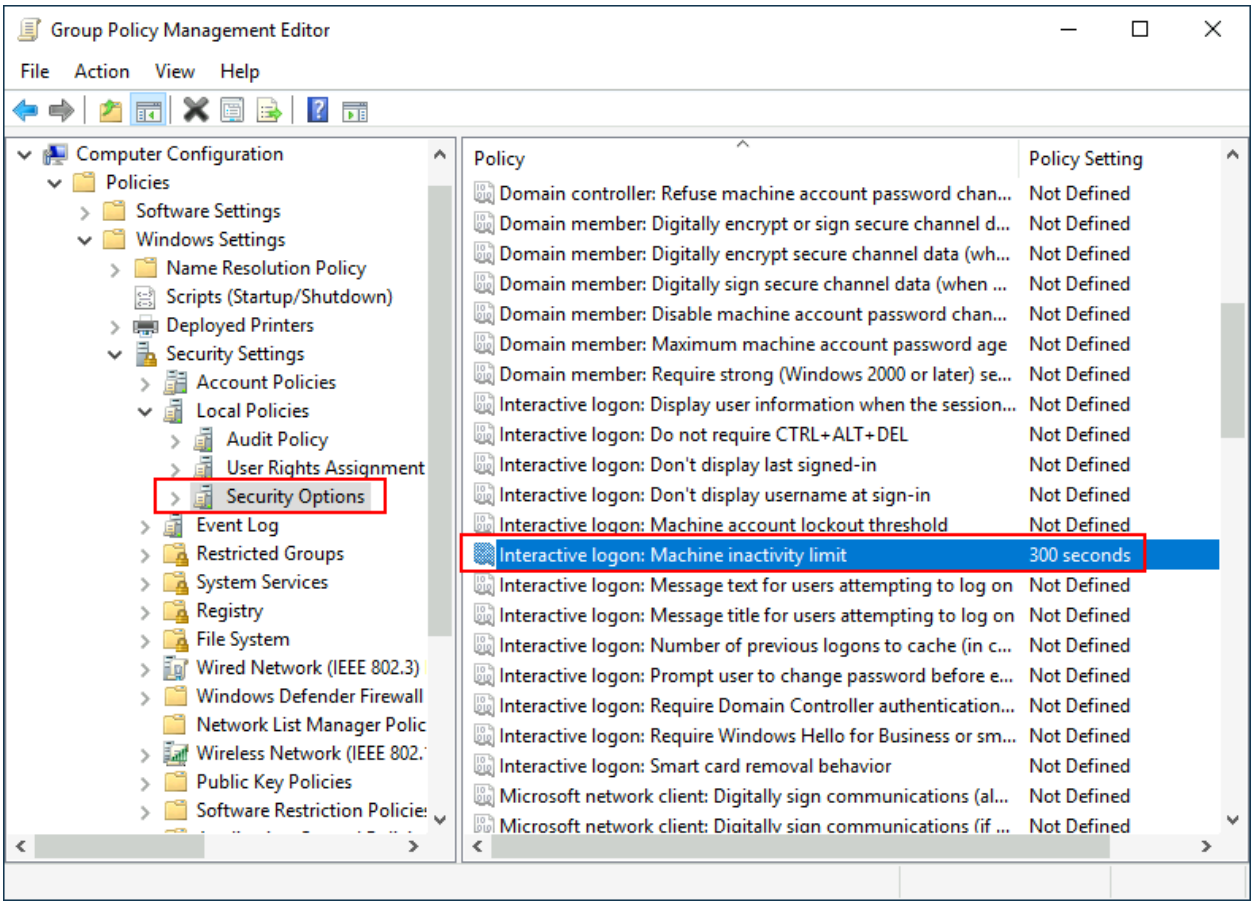


Notice we have enabled the **Prohibit Access to Control Panel and PC settings** policy. Once the GPO is configured, we will need to link it to all of the OUs corresponding to users who shouldn't have access to the Control Panel of their PCs. In this case, we will link the `Marketing`, `Management` and `Sales` OUs by dragging the GPO to each of them:

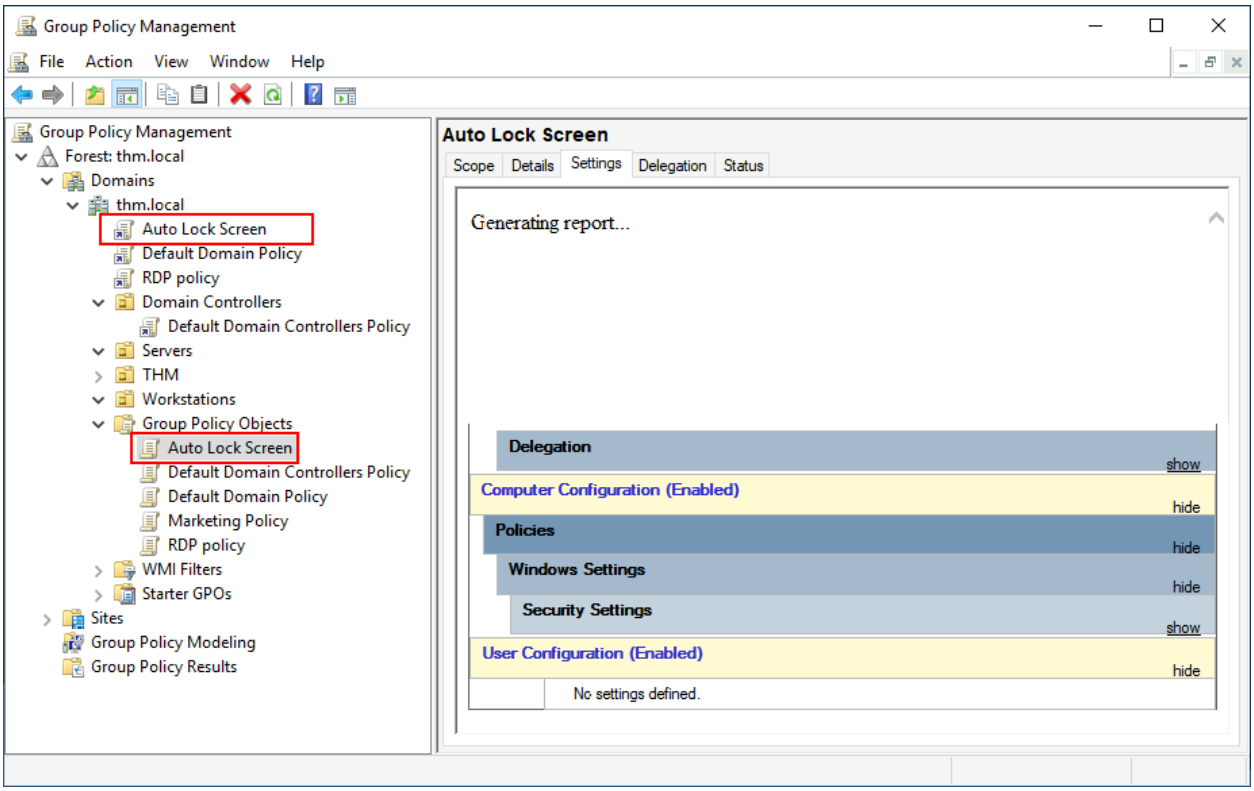


Auto Lock Screen GPO: For the first GPO, regarding screen locking for workstations and servers, we could directly apply it over the `Workstations`, `Servers` and `Domain Controllers` OUs we created previously. While this solution should work, an alternative consists of simply applying the GPO to the root domain, as we want the GPO to affect all of our computers. Since the `Workstations`, `Servers` and `Domain Controllers` OUs are all child OUs of the root domain, they will inherit its policies.

Note: You might notice that if our GPO is applied to the root domain, it will also be inherited by other OUs like `Sales` or `Marketing`. Since these OUs contain users only, any Computer Configuration in our GPO will be ignored by them. Let's create a new GPO, call it `Auto Lock Screen`, and edit it. The policy to achieve what we want is located in the following route:



We will set the inactivity limit to 5 minutes so that computers get locked automatically if any user leaves their session open. After closing the GPO editor, we will link the GPO to the root domain by dragging the GPO to it:



Answer the questions below

> What is the name of the network share used to distribute GPOs to domain machines? sysvol

> Can a GPO be used to apply settings to users and computers? (yay/nay) yay

Task 7 - Authentication Methods

When using Windows domains, all credentials are stored in the Domain Controllers. Whenever a user tries to authenticate to a service using domain credentials, the service will need to ask the Domain Controller to verify if they are correct. Two protocols can be used for network authentication in windows domains:

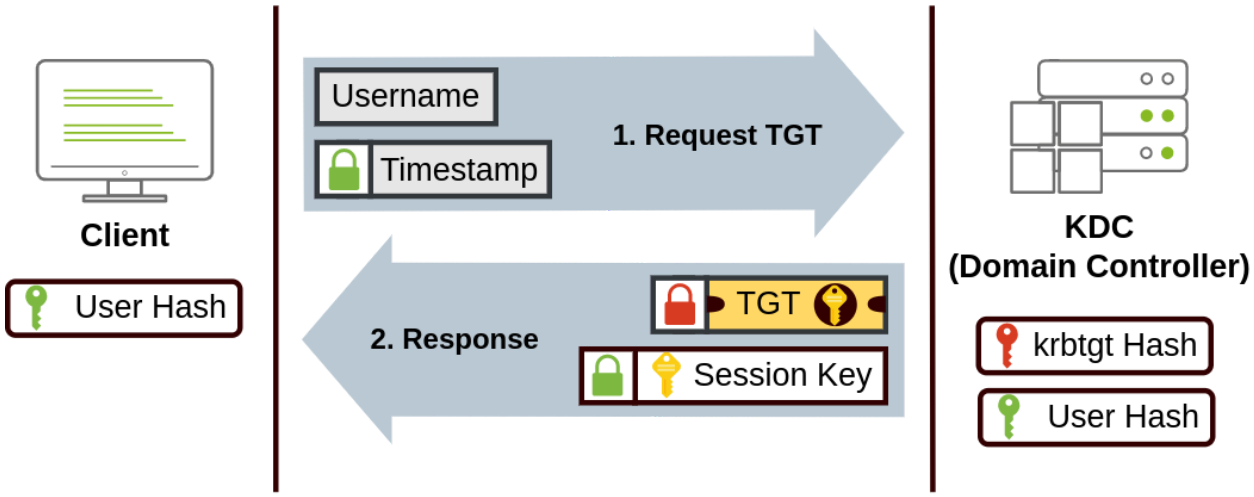
- **Kerberos:** Used by any recent version of Windows. This is the default protocol in any recent domain.
- **NetNTLM:** Legacy authentication protocol kept for compatibility purposes.

Kerberos Authentication: Kerberos authentication is the default authentication protocol for any recent version of Windows. Users who log into a service using Kerberos will be assigned tickets. Think of tickets as proof of a previous authentication. Users with tickets can present them to a service to demonstrate they have already authenticated into the network before and are therefore enabled to use it. When Kerberos is used for authentication, the following process happens:

1. The user sends their username and a timestamp encrypted using a key derived from their password to the **Key Distribution Center (KDC)**, a service usually installed on the Domain Controller in charge of creating Kerberos tickets on the network.

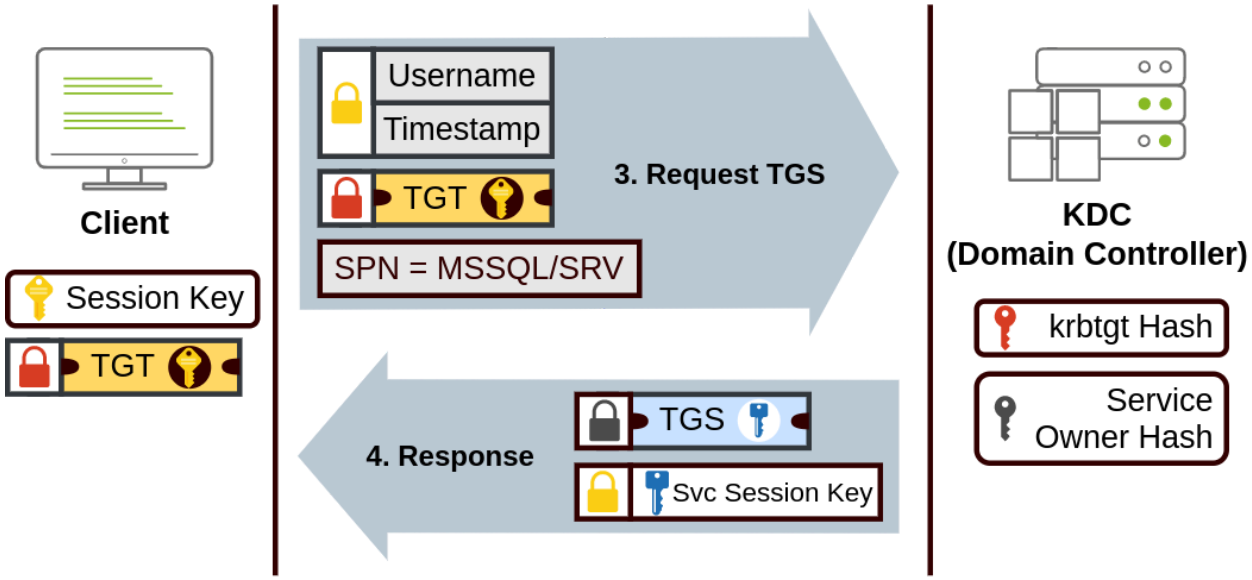
   The KDC will create and send back a **Ticket Granting Ticket (TGT)**, which will allow the user to request additional tickets to access specific services. The need for a ticket to get more tickets may sound a bit weird, but it allows users to request service tickets without passing their credentials every time they want to connect to a service. Along with the TGT, a **Session Key** is given to the user, which they will need to generate the following requests.

   Notice the TGT is encrypted using the **krbtgt** account's password hash, and therefore the user can't access its contents. It is essential to know that the encrypted TGT includes a copy of the Session Key as part of its contents, and the KDC has no need to store the Session Key as it can recover a copy by decrypting the TGT if needed.

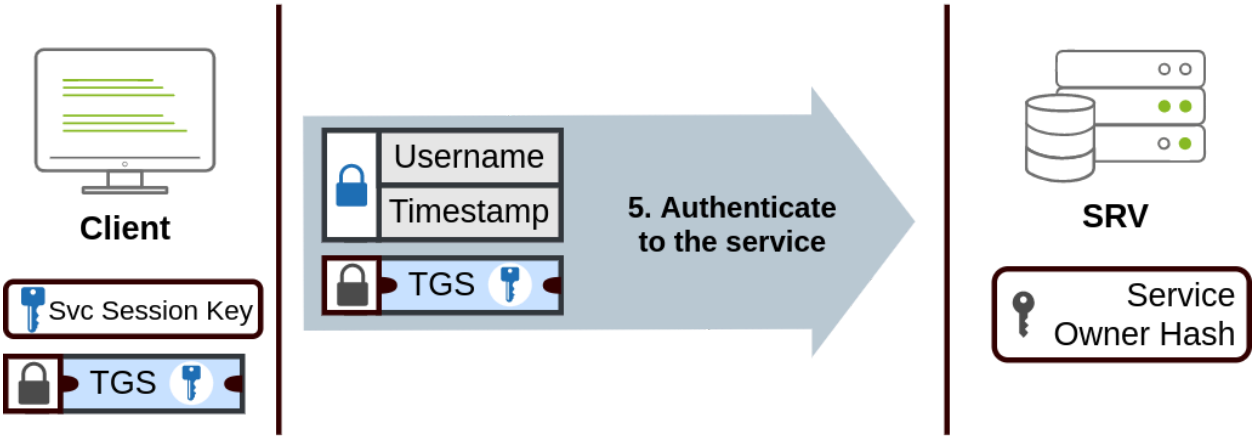


1. When a user wants to connect to a service on the network like a share, website or database, they will use their TGT to ask the KDC for a **Ticket Granting Service (TGS)**. TGS are tickets that allow connection only to the specific service they were created for. To request a TGS, the user will send their username and a timestamp encrypted using the Session Key, along with the TGT and a **Service Principal Name (SPN),** which indicates the service and server name we intend to access.

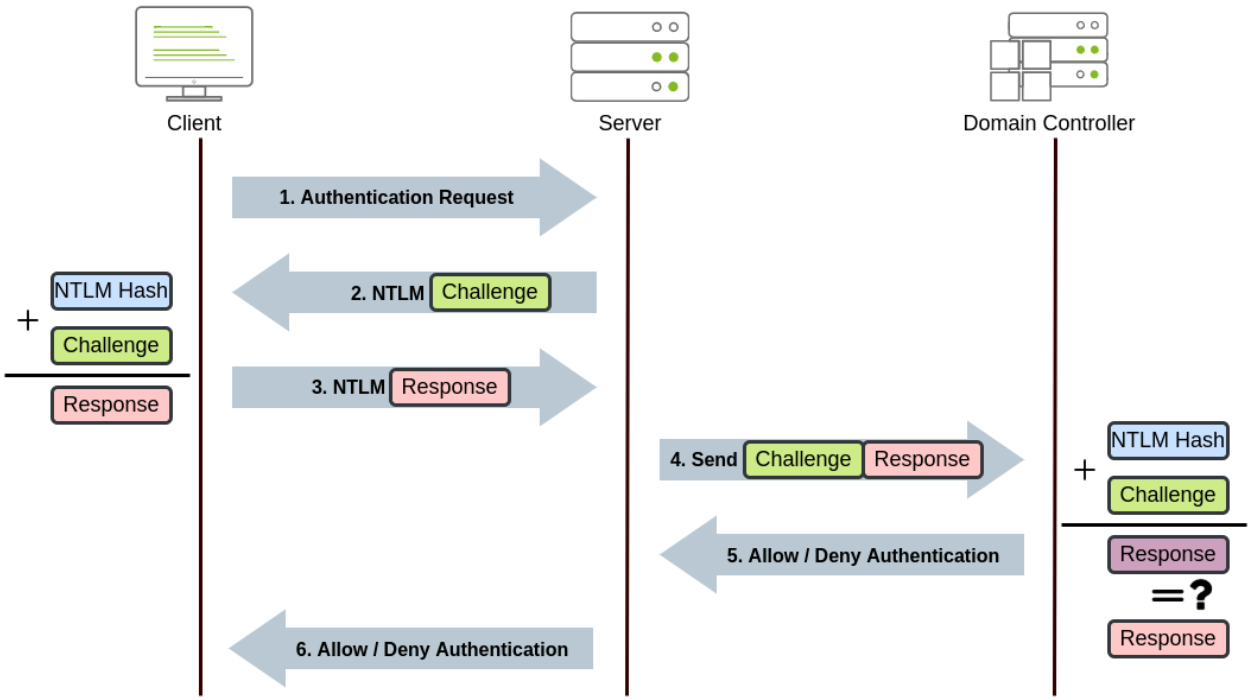
   As a result, the KDC will send us a TGS along with a **Service Session Key**, which we will need to authenticate to the service we want to access.
   The TGS is encrypted using a key derived from the **Service Owner Hash**. The Service Owner is the user or machine account that the service runs under.
   The TGS contains a copy of the Service Session Key on its encrypted contents so that the Service Owner can access it by decrypting the TGS.



1. The TGS can then be sent to the desired service to authenticate and establish a connection. The service will use its configured account's password hash to decrypt the TGS and validate the Service Session Key.



NetNTLM Authentication: NetNTLM works using a challenge-response mechanism. The entire process is as follows:



1. The client sends an authentication request to the server they want to access.
2. The server generates a random number and sends it as a challenge to the client.
3. The client combines their NTLM password hash with the challenge (and other known data) to generate a response to the challenge and sends it back to the server for verification.

4. The server forwards the challenge and the response to the Domain Controller for verification.
5. The domain controller uses the challenge to recalculate the response and compares it to the original response sent by the client. If they both match, the client is authenticated; otherwise, access is denied. The authentication result is sent back to the server.
6. The server forwards the authentication result to the client.

Answer the questions below

> Will a current version of Windows use NetNTLM as the preferred authentication protocol by default? nay

> When referring to Kerberos, what type of ticket allows us to request further tickets known as TGS? Ticket Granting Ticket

> When using NetNTLM, is a user's password transmitted over the network at any point? nay

Task 8 - Trees, Forests and Trusts

Trees: A **tree** in Active Directory is a group of one or more domains that share a continuous namespace and are connected hierarchically. All domains in the tree automatically trust each other. **Example:**

- company.com (root domain)
- hr.company.com (child domain)
- it.company.com (child domain)

Forests: A **forest** is the highest-level Active Directory structure. It contains one or more trees that share a common schema, configuration, and Global Catalog. These domains can have different names but belong to the same forest and can share resources. **Example:**

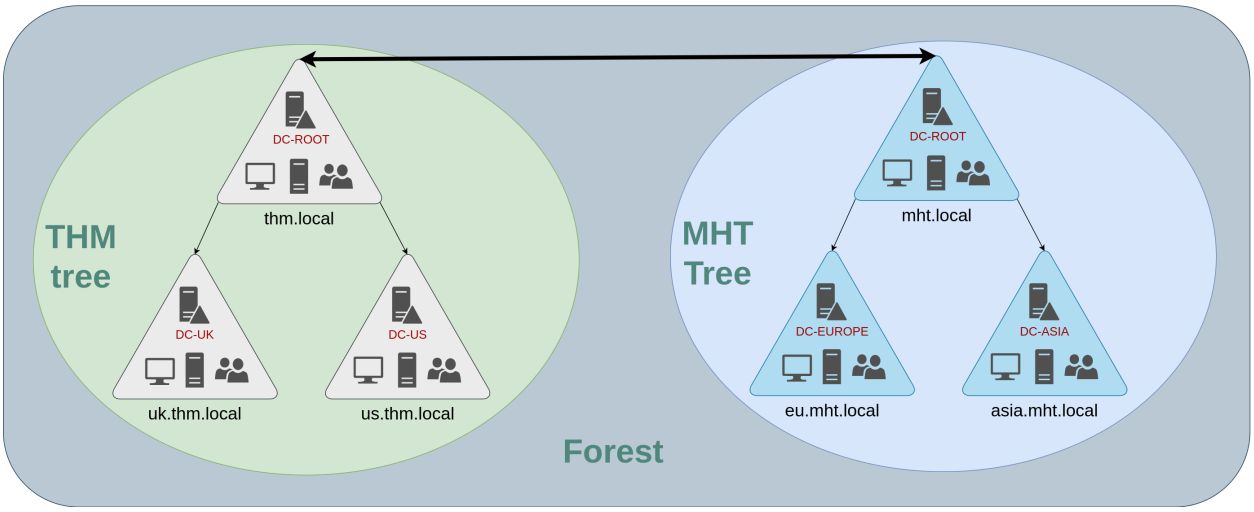
- company.com
- anothercompany.net

Trust Relationship: A **trust relationship** allows users in one domain or forest to access resources in another domain or forest. **Types of Trusts:**

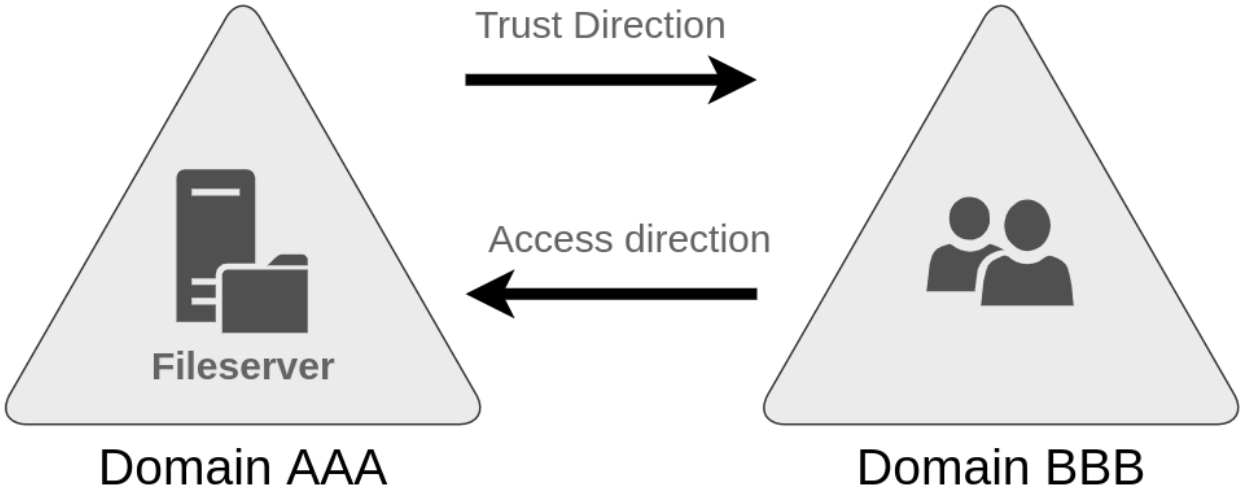
- **Parent-Child Trust** – Automatically created between parent and child domains.
- **Tree-Root Trust** – Automatically created between trees in the same forest.
- **External Trust** – Connects domains in different forests.
- **Forest Trust** – Connects entire forests.

Example: A user from **hr.company.com** can access a file server in **it.company.com** because a trust relationship exists between the domains.

- **Tree:** A group of related domains sharing a namespace.
- **Forest:** A collection of one or more trees sharing the same Active Directory infrastructure.
- **Trust Relationship:** A connection that allows users and resources to be accessed across domains or forests.



Trust Relationships



Answer the questions below

> What is a group of Windows domains that share the same namespace called?
> Tree

> What should be configured between two domains for a user in Domain A to access a resource in Domain B? A Trust Relationship